Network forensics principles and practice

Dr Olga Angelopoulou

ROYAL HOLLOWAY UNIVERSITY OF LONDON

Learning outcomes

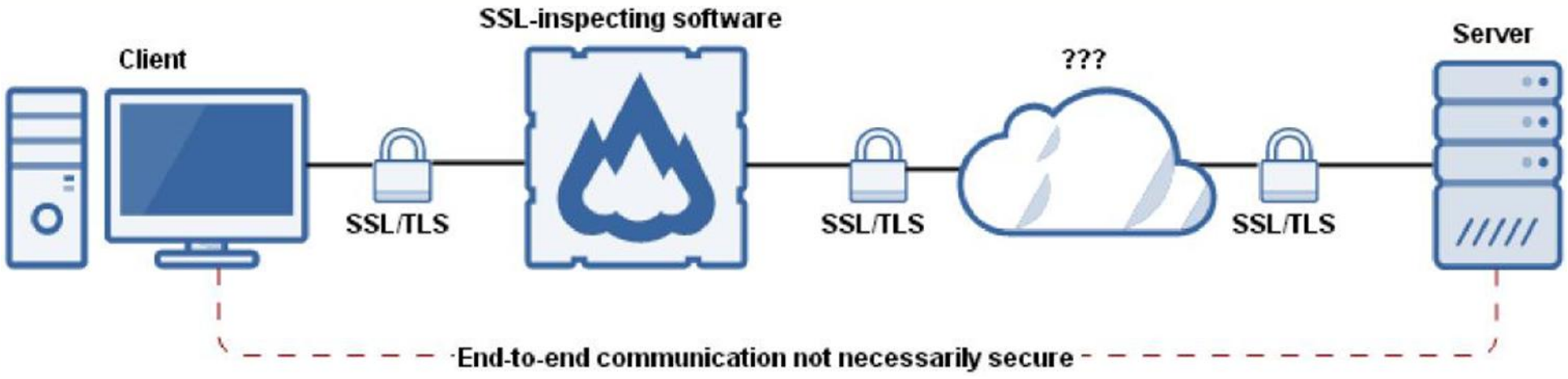
- Identify the different types of network-based evidence
- (Remote) scanning techniques
- A review of IPv4 and IPv6 information from a forensic perspective
- Forensic information obtainable from TCP header information and packet formatting
- Observation of network traffic: Tools, techniques, and limitations

Network Forensics

- *" the act of capturing, recording, and analysing network audit trails in order to discover the source of security breaches or other information assurance problems."*

- Packets can be inspected on the fly or stored on disk for later analysis.

- The investigator and the attacker are usually at the same level of knowledge of the system
- They usually use the same tools to gain information about the network



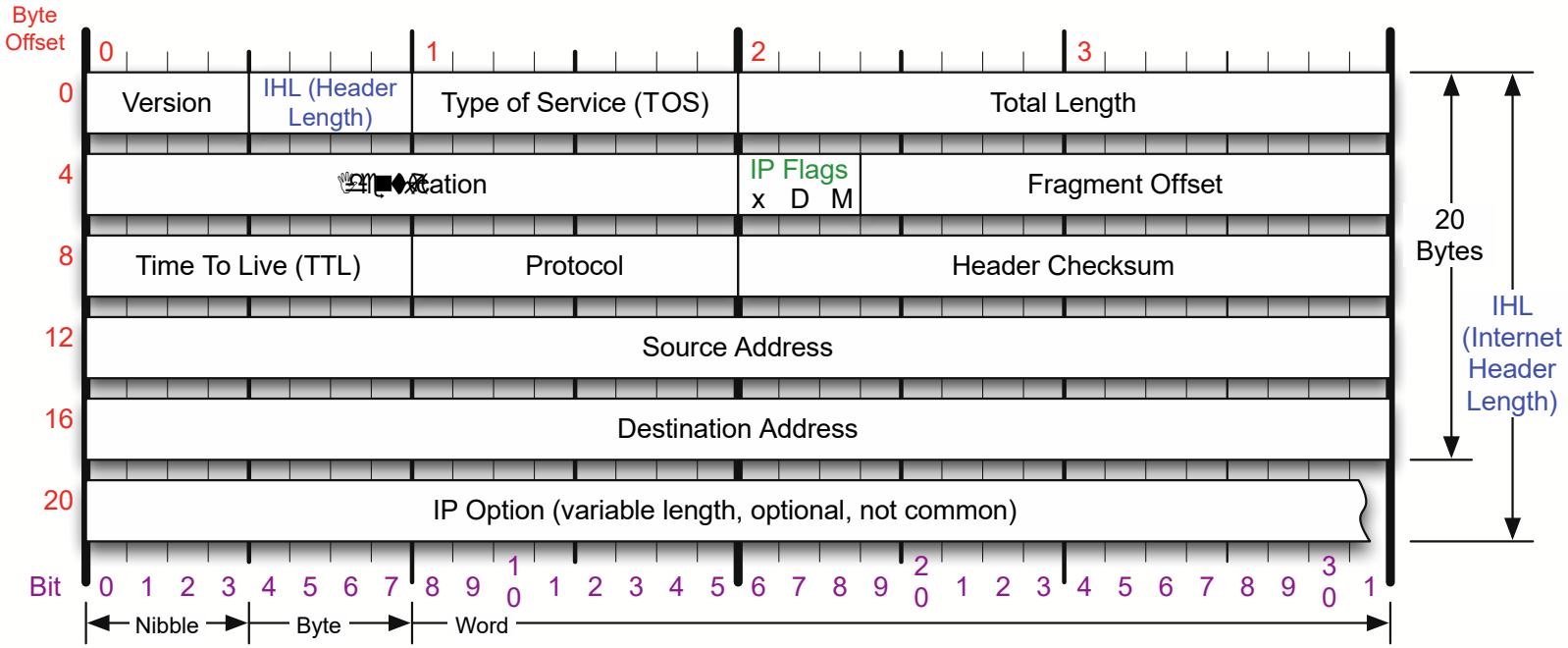
Issues

- The age of encryption
- Ever increasing bandwidth
- Volatility - Temporary
- Many locations
  - Computer systems
  - Network components
- Size
- Fragmentation
- Volume of data

TCP/IP Protocol Review

ROYAL HOLLOWAY UNIVERSITY OF LONDON

IP Version 4 Header



The Version 4 Internet Protocol header precedes the payload protocol and contains a number of fields of potential interest

- Unusual combinations of fields may, e.g., indicate malware presence (use of covert channels)

IPv4 Header – Selected Fields (1/3)

Version: Always 4 for IP Version 4

Internet Header Length: Number of 32-bit words in the header (minimum: 20 bytes, maximum: 60 bytes)

TOS/DS: Originally the **Type of Service** field, this usage is now obsolete. Instead, the field is used for **Explicit Congestion Notification** (RFC 3168) and **Differentiated Services** (RFC 2474) in line with IPv6 usage

Total Length: Total length of datagram (minimum: 20 bytes for a single header). Networks must handle a packet size of at least 576 bytes

IPv4 Header – Selected Fields (2/3)

Identification: Original purpose was to identify fragments

Flags: Identifies presence of additional fragments (MF) or prohibition of fragmentation (DF)

Fragmentation Offset: Measured in 8-byte blocks identifies the offset of a fragment relative to the full IP datagram

Time to Live: Decremented on transiting networks (typically per hop)

Protocol: Type of protocol used (e.g., TCP, UDP)

Header Checksum: 1-complement checksum over selected header fields, checksum field itself is considered as zero in this; must be re-computed on each hop as at least the TTL field will change

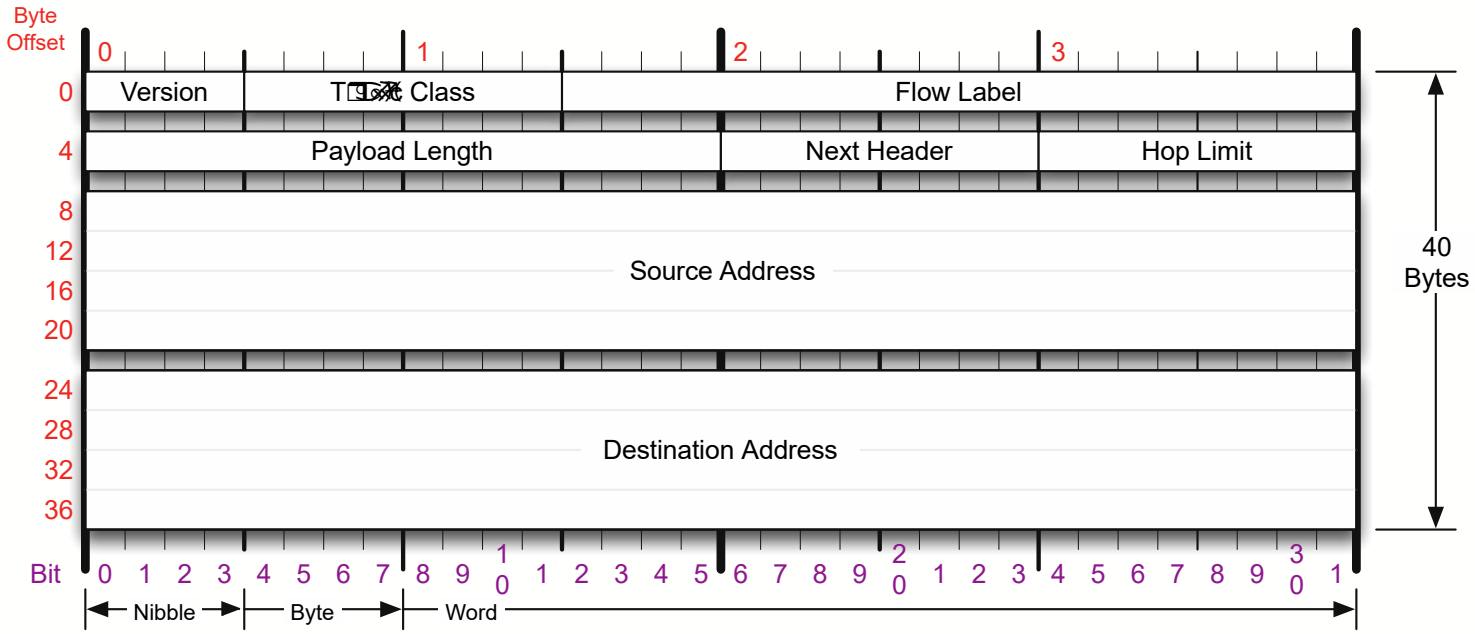
IPv4 Header – Selected Fields (3/3)

Source Address: IP address, as with other fields not integrity-protected and will also be changed for legitimate reasons, e.g., **network address translation** (NAT/PAT)

Destination Address: May also be subject to address translation

Options: Rarely used, currently 26 option types recognized by IANA plus experimental options – largely obsolete and will frequently be filtered by firewalls

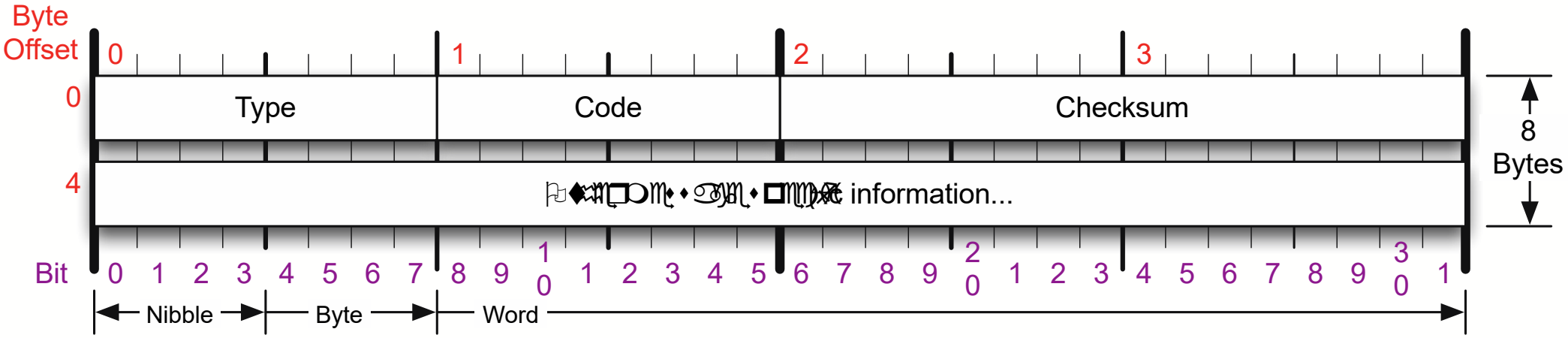
IP Version 6 Header



The IP Version 6 header has been optimized for current-generation processors and has in many respects also been sanitized

- Infrequently used options and settings were removed
- Explicit low-level flow and traffic class labels allow rapid processing

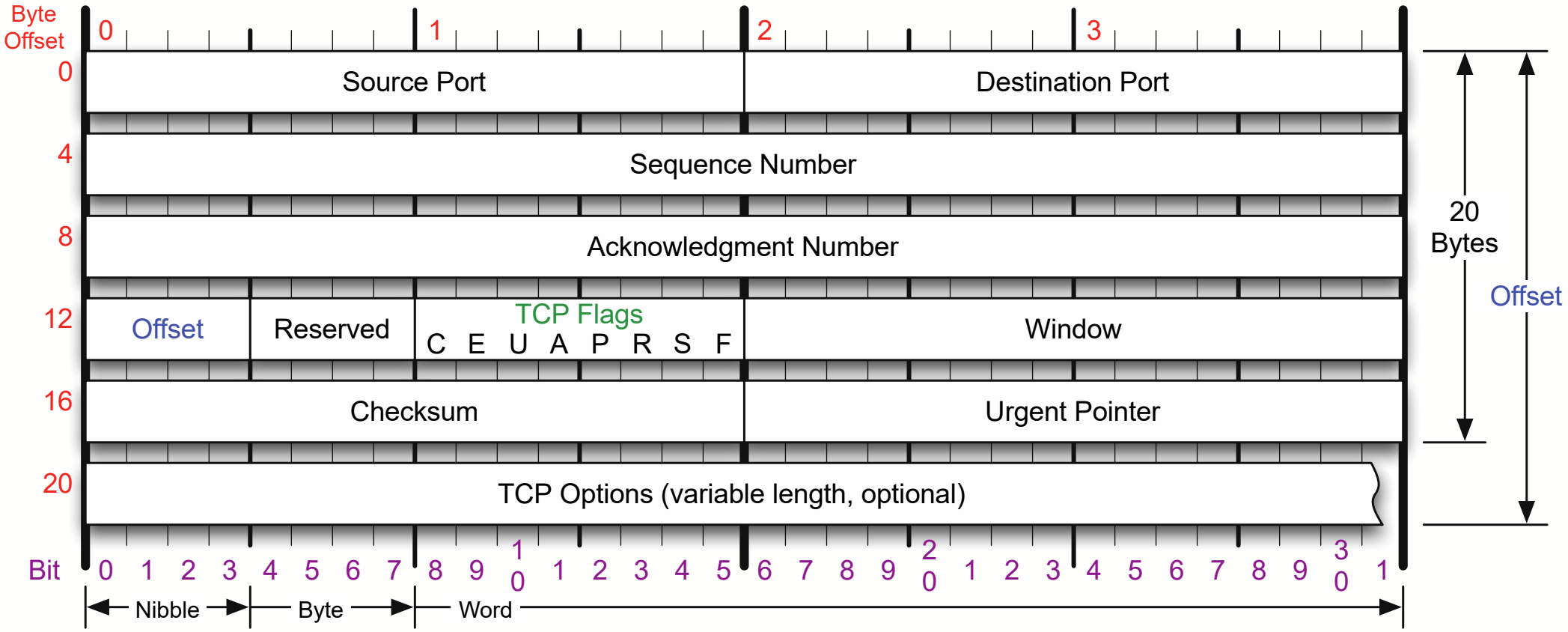
ICMP Header



Most of ICMP header content depends on the precise type and code for a given message

- The length of the ICMP message is implicit in the type and will vary, but is at most that of a single IP packet (65507 bytes: 65535 bytes maximum IP packet size, deducting 20 bytes for a minimum IP header and 8 bytes for the ICMP header)

TCP Header


Byte Offset
0
1
2
3
0
Source Port
Destination Port
4
Sequence Number
8
Acknowledgment Number
12
Offset
Reserved
TCP Flags
C E U A P R S F
Window
16
Checksum
Urgent Pointer
20
TCP Options (variable length, optional)
20 Bytes
Offset
Bit
0 1 2 3 4 5 6 7 8 9 10 1 2 3 4 5 6 7 8 9 20 1 2 3 4 5 6 7 8 9 30 1
Nibble
Byte
Word

TCP Segment Header Fields (1/3)

Source Port: Identifies sending port, may be altered by **Port Address Translation** (PAT)

Destination Port: Identifies destination, may also be modified by PAT gateway or on destination host

Sequence Number: Initial sequence number (ISN) on initiation of session, or byte sequence count in current session beginning with ISN

Acknowledgment Number: Dual of Sequence Number to acknowledge received byte stream, serves as index to received bytes

Data Offset: Size of header (in 4-byte increments), minimum is 20 bytes, maximum 60 bytes

TCP Segment Header Fields (2/3)

The **Flags** field in the TCP segment header holds the following possible values:

- **CWR:** Congestion Window Reduced (used for ECN acknowledgment)
- **ECE:** Explicit Congestion Notification (RFC 3168) configuration and capability statement
- **URG:** Urgent pointer should be evaluated
- **ACK:** Acknowledgment field is significant
- **PSH:** Request to forward buffered data up protocol stack to application
- **RST:** Reset session (error condition) SYN Session initiation request
- **FIN:** Session termination request or acknowledgment

TCP Segment Header Fields (3/3)

Window: Size of **receive window**, set by recipient

Checksum: 1-complement checksum over non-variable fields

Urgent Pointer: Offset from sequence number indicating last urgent byte

Options: Length may vary, a number of standardized and experimental options exist, some (e.g. selective acknowledgement) have significant impact on protocol behavior.

IP Network Scanning Techniques (1/2)

Once a host has been identified as live, different techniques can be employed for identifying active services (ports)

SYN Scanning: A TCP SYN segment is sent, and the scanner records an active port on receiving a SYN/ACK segment or a closed port when seeing a RST segment. Non-response or *ICMP Unreachable* error may indicate filtered port

TCP Connect: Scan Attempts to perform regular connection attempt, may cause fewer IDS alerts to be raised compared to SYN scanning

UDP Scanning: For a stateless protocol such as UDP, eliciting responses may be difficult: Applications may ignore mal-formed requests, or those not matching current protocol state

IP Network Scanning Techniques (2/2)

SCTP INIT Scan: In addition to TCP and UDP, SCTP may also be active on a link, and STCP INIT provides the equivalent of a SYN scan and similar information

Flag Scan: Implementations may react differently to having TCP options set in the TCP flag header, but as their use is not legitimate this will typically be identified by IDS or firewalls

TCP Scans: Using TCP segments that would otherwise only be seen in active connections, reply behavior can identify active ports

Discussion Point 1

Network forensics relies heavily on captured traffic and logs.

To what extent can investigators ever be confident that they are seeing the full picture of an incident, and how should gaps in network visibility be handled in forensic reporting?

Plan:

- What are you capturing? Everything or selected servers/ protocols ?

- How are you capturing?

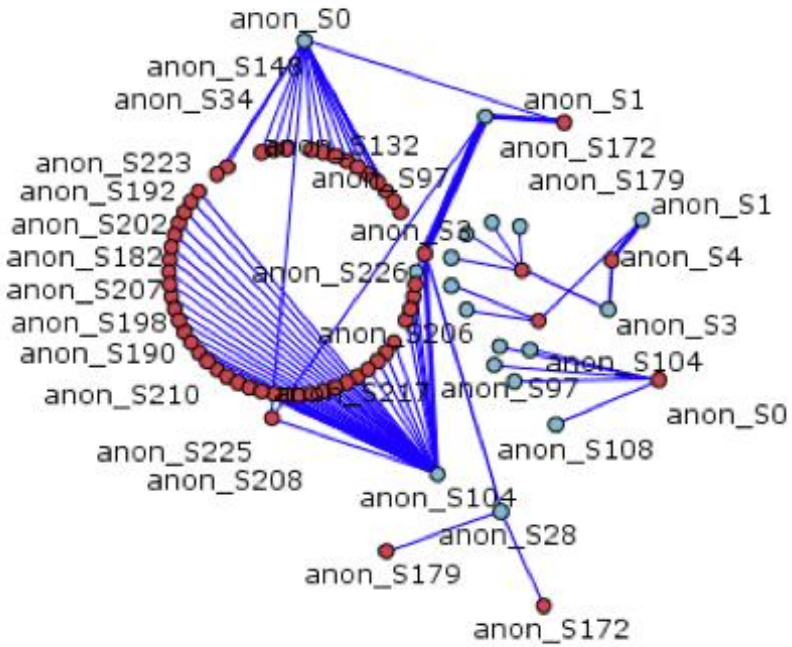
- Where / How are you storing it? How long for?

Capturing Network Traffic

ROYAL HOLLOWAY UNIVERSITY OF LONDON

Where to look for evidence?

- All OSI layers
  - local Ethernet segments
  - Bluetooth piconets
  - 802.11 (Wifi) hotspots
  - database servers
  - DNS and whois servers
  - websites
  - ftp servers
  - chat servers
  - Usenet servers
  - network routing tables
  - responses from SNMP servers
  - reply messages from SOAP servlets



Network-Based Forensics Sources

- Some information available from host systems can also be obtained over the network by active or passive scans
  - Useful for validating information obtained on hosts, but necessarily limited in detail and may suffer from observation errors
- Scanning techniques will seek to establish
  - Availability of host (existence of a responding host for a given address)
  - **Fingerprinting** of host operating system to ensure baseline for interpretation of subsequent data
  - Querying of available (responding) services
    - Not all services may be visible or respond to straightforward enquiries
    - Firewalls, but also protocol state dependencies up to **port knocking** requirements

Operating System Fingerprinting

ROYAL HOLLOWAY UNIVERSITY OF LONDON

Operating system fingerprinting

- Response behavior to various network queries will vary based on implementation and configuration in a given host including operating system revision level but also, e.g., firewall configuration
- Behavior can be masqueraded, but that itself may be conspicuous and can identify high-value targets

Application mapping

- Network-visible applications can often be identified, usually also including revision information
- Banner grabbing or other version information – for some services explicit service discovery mechanisms makes scanning and mapping are trivial

Several tools exist, one of the most common ones is **Nmap**

Nmap Command-Line Interface

Sample scan of a long-deceased printer (Xerox Phaser 6280) system using the Nmap CLI

figures — bash — 80×47

```
Scanning 10.0.1.6 [1000 ports]
Discovered open port 21/tcp on 10.0.1.6
Discovered open port 445/tcp on 10.0.1.6
Discovered open port 23/tcp on 10.0.1.6
Discovered open port 80/tcp on 10.0.1.6
Discovered open port 139/tcp on 10.0.1.6
Discovered open port 9100/tcp on 10.0.1.6
Discovered open port 515/tcp on 10.0.1.6
Discovered open port 631/tcp on 10.0.1.6
Increasing send delay for 10.0.1.6 from 0 to 5 due to max_successful_tryno incre
ase to 4
Completed SYN Stealth Scan at 09:01, 7.19s elapsed (1000 total ports)
Initiating Service scan at 09:01
Scanning 7 services on 10.0.1.6
Completed Service scan at 09:01, 6.07s elapsed (8 services on 1 host)
Initiating OS detection (try #1) against 10.0.1.6
NSE: Script scanning 10.0.1.6.
Initiating NSE at 09:01
Completed NSE at 09:01, 0.03s elapsed
Nmap scan report for 10.0.1.6
Host is up (0.00037s latency).
Not shown: 992 closed ports
PORT     STATE SERVICE      VERSION
21/tcp   open  ftp          Xerox Phaser 6280DN printer ftpd
23/tcp   open  telnet       Cisco or Edge-core switch telnetd
80/tcp   open  http         EWS-NIC4 13.39 (Xerox Phaser 6280DN printer http con
fig)
139/tcp  open  netbios-ssn?
445/tcp  open  microsoft-ds Xerox WorkCentre 5225 printer microsoft-ds
515/tcp  open  printer
631/tcp  open  ipp          Xerox WorkCentre IPP
9100/tcp open  jetdirect?
MAC Address: 00:00:AA:AC:23:8C (Xerox)
Device type: general purpose
Running: Wind River VxWorks
OS CPE: cpe:/o:windriver:vxworks
OS details: VxWorks
Uptime guess: 25.716 days (since Thu Jan  9 15:50:35 2014)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=257 (Good luck!)
IP ID Sequence Generation: Incremental
Service Info: Devices: printer, switch; CPE: cpe:/h:xerox:phaser_6280dn

Read data files from: /usr/local/bin/../share/nmap
OS and Service detection performed. Please report any incorrect results at http:
//nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.94 seconds
```

Observing Network Traffic

Observing (or **sniffing**) network traffic becomes necessary when hosts cannot be used for such observations

- This may be the case when hosts cannot be assumed to be trustworthy
- Similarly, when observations affect aggregate traffic not limited to individual endpoints

Observation can occur at multiple locations

- **Active** network components allow capturing of traffic, but have restrictions in traffic volume and may themselves be observed
- **Passive** observation (which may in some cases also be detected) avoids such possible contamination
  - This was trivial to achieve with old 10Base2, 10Base5, and 10BaseT networks, but more complex for fast copper or optical networks – i.e., anything since the mid-90s

What to look for?

- malicious webpages, illegal files, and intellectual property abuse
- TLS/SSL and other cryptographic certificate info
- traffic from port scans and vulnerability scans
- routing tables, network distance (hops), ttl
- Hardware manufacturer (from the MAC address), physical distance between nodes
- protocol encapsulation (raw Ethernet, 802.3, 802.2, 802.11)
- frame size, maximum transmission unit (MTU), line speed, wireless signal strength and direction

Formats and Tools

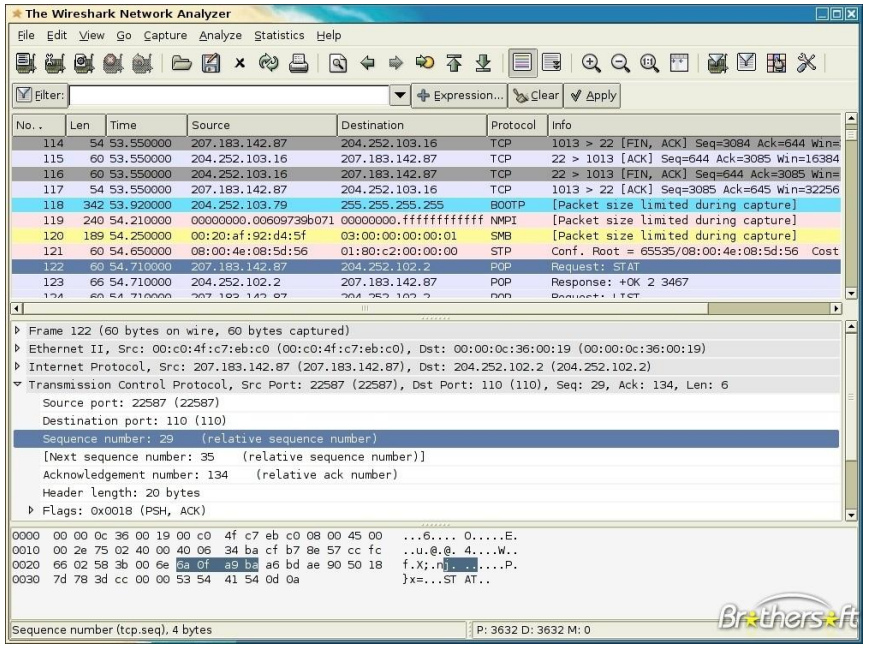
- PCAP Files: standard format for “Packet CAPture”
  - Binary format
  - Raw packet data with some headers that include relevant
  - metadata

- Command line and GUI Tools
  - tcpdump
  - Wireshark
  - IDS/Firewall

Host-Based Network Traffic Capture

A number software-based tools can provide network traffic capturing on local machines (or when capturing traffic diverted via taps)

- Exact implementation is platform-dependent (but output is usually pcap)
- Wireshark provides a cross-platform layer on the platform-specific raw device capturing mechanisms and allows parsing of numerous protocols



Protocol Analysis

Adversaries may seek to obfuscate network traffic in a number of ways:

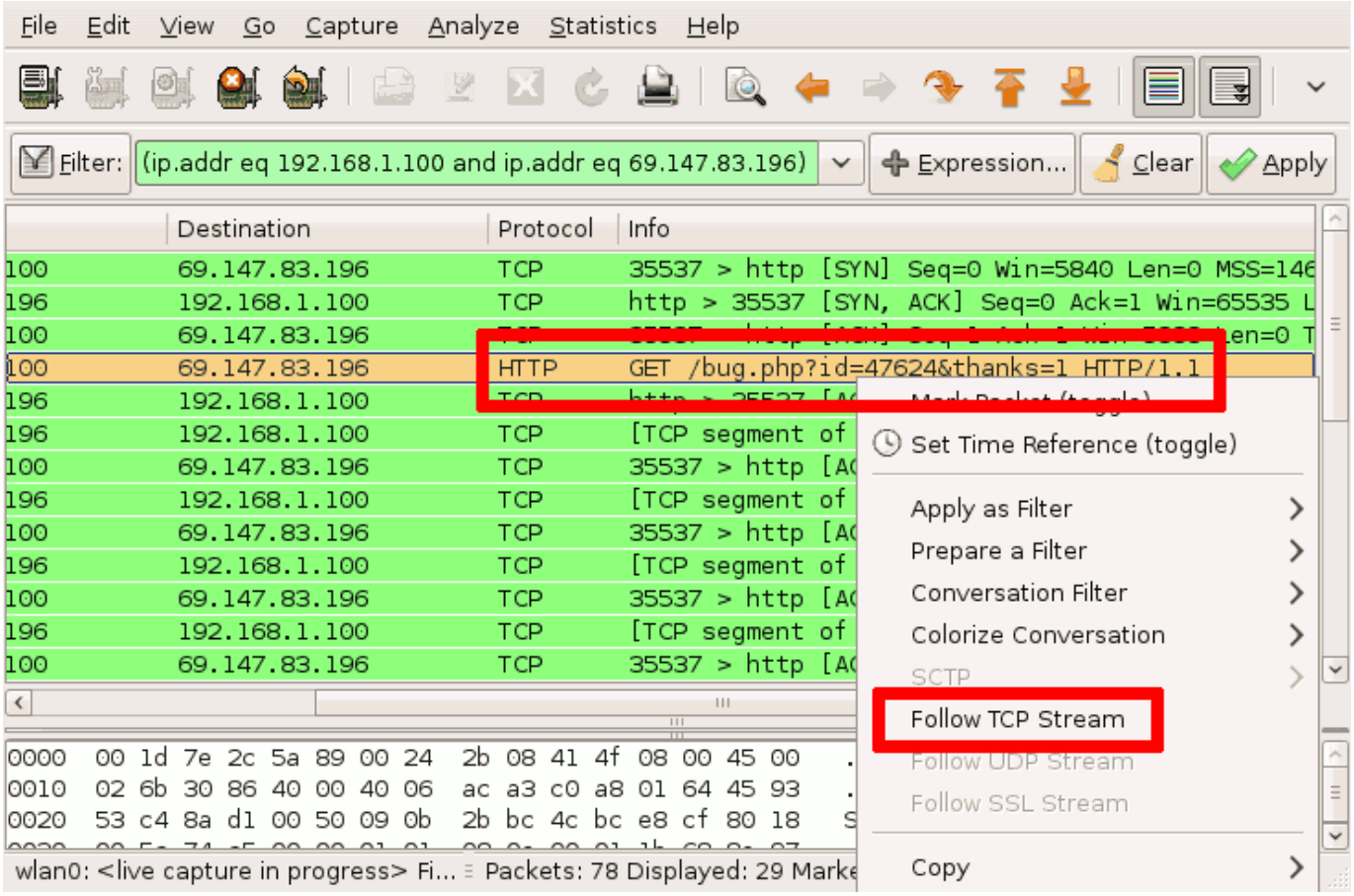
- Simply using a non-canonical port may sometimes suffice
- **Nesting** protocols or some other encoding requires tool support (which may yield host-based evidence)

Where **obfuscation** is suspected, actual traffic capture and **protocol analysis** may be required

- Tools such as Wireshark may help, but for custom protocols, manual reverse engineering may be required
- This assumes that sufficient traffic is (fully) captured and no disfiguring gaps prevent decoding a protocol or leaving ambiguities

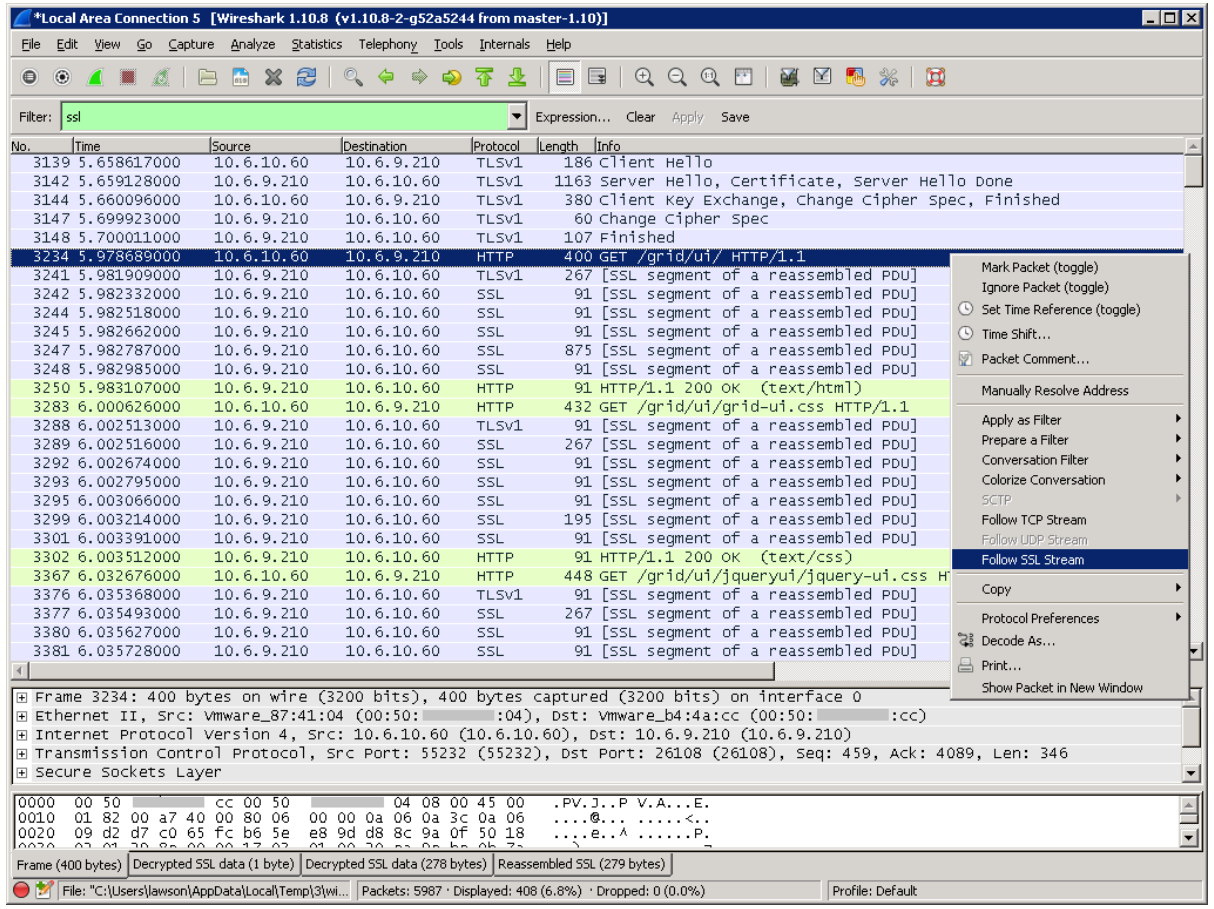
Protocol Analysis Tools – Wireshark Features (1/2)

TCP streams can be reassembled (if not always exactly as the host sees them!):



Protocol Analysis Tools – Wireshark Features (2/2)

If key material is available, this can also include TLS streams:



Network Traffic Capture Issues

ROYAL HOLLOWAY UNIVERSITY OF LONDON

- Capturing can occur at different levels of detail
  - Header information only
  - Selected packet length
  - Full capture
- All capture modes may not capture traffic with absolute reliability or precision – this may require specialized hardware satisfying hard real-time constraints
  - Particularly for full capture, data volumes can quickly become problematic
  - 40 GBit/s links are found in backbone network and some server systems (increasingly also linked via trunking) – OC-768 operates at 40Gbit/s and is used in single fibre backbones also for long-haul links
  - Even at modest loads, this can easily exceed the transfer capacity of enterprise-class hard disks
  - On most commodity hardware, I/O throughput becomes an issue

Network Flow Analysis

If either just header information is available or (from active network components or dedicated probes) only **network flows** this may still be useful as evidence or to guide investigations:

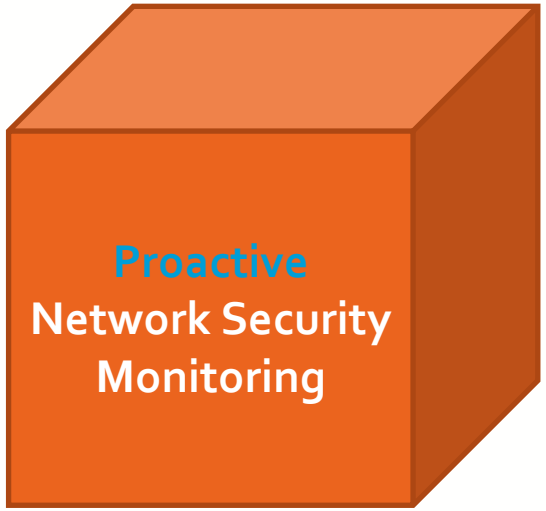
- Identification of compromised hosts, proving (or disproving) information "leakage", profiling of individual users
- Flows are statistical aggregates initially introduced by Cisco for monitoring and management of network components, and (in v.9) identify interfaces, source and destination addresses, (TCP/UDP) ports and types of service along with some routing information, time stamps, and packets/bytes in the flow

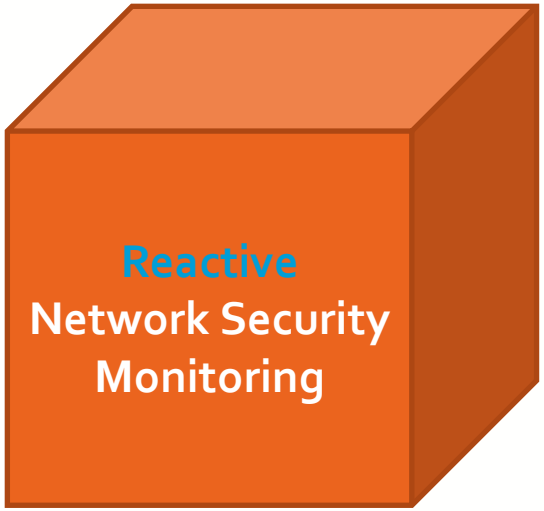
More commonly used in incident response and analysis, the statistical information may still be useful in establishing hypotheses or addressing some simple questions

Types of Network based evidence

ROYAL HOLLOWAY UNIVERSITY OF LONDON

Network based evidence in practise





Detects intrusions	Employed on demand
When they occur	In a crisis
Shortly after	To augment standard monitoring practises

Full Content Data

- Proactive technique
- Actual transmitted packets
  - Headers
  - Application information
- Record every packet traversing the organisation's network.
- Review unencrypted packet content to understand the communication between two computers
  - User names and passwords
  - Intruder commands
  - Other sensitive information

- Challenging for physical collection and storage of such data volumes
- Requires great amount of work
- We care about the conversations the packets create, not the individual characteristics

Session Data

- Collects both proactive and reactive modes
- Aggregation of packets into groups of associated packets
  - Patterns of activity for encrypted communications
  - It is more important to know the communication between two packets rather than the actual content of the packets

Alert Data

- Predefined items of interest
  - Network IDS: recognises patterns of bits, sorts of malicious activity, traffic characteristics for signs of policy violations (IDS signatures)
  - IDS often report false negative alerts
    - Tuning the IDS to ignore routine traffic prevents these alerts
    - Requires a lot of time and effort
  - Decryption limits the IDS effectiveness

- Alert data is granular and specific
- We are more interested in the general nature of the traffic and less in the specific characteristics of packets, flows etc.

Statistical Data

- Measure the health and performance of the network
  - E.g. which services or protocols transfer most data on the network

- Full content, session and alert are compounded if the communication is encrypted; statistical data is not affected
  - Large amounts of encrypted traffic indicate secure file transfers
  - Smaller amounts indicate could be administrative channels
- More useful as an indicator to another Network based evidence type

Network Traffic Analysis Issues

- Correlating events across networks – especially with multiple nodes – suffers from the usual problems of showing synchronization
- Timestamps are never perfectly synchronized, but for high-speed networks this increases the likelihood of distortions by mis-ordering
- This can jeopardize causation analysis or the detection and recognition of communication patterns unless explicit synchronization occurs at higher levels
  - e.g., within a TCP flow
- Similar to capture information, network flows may not be recorded reliably (some sites may use UDP for communication!) and must be integrity-protected

Discussion Point 2

- Network traffic can reveal highly sensitive personal and organisational information.
- How should forensic practitioners balance the need to investigate incidents with the responsibility to minimise intrusion into unrelated users' data?

Summary

- Network Forensics focuses on capturing, analysing, and interpreting network traffic and logs
- Common evidence sources include:
  - Packet captures (PCAPs)Firewall
  - IDS/IPS, and server logs
  - Flow data (e.g. NetFlow)
- Used to:
  - Identify malicious activity
  - Reconstruct timelines
  - Understand attacker behaviour
- Key challenges:
  - Incomplete visibility and missing data
  - Encryption and anonymisation
  - High data volumes and noise

Questions?

ROYAL HOLLOWAY UNIVERSITY OF LONDON